

Challenge: Yellow RAT Lab

Platform: SOC Analyst Tier 1

Category: Threat Intel

Tactics: Initial Access, Execution

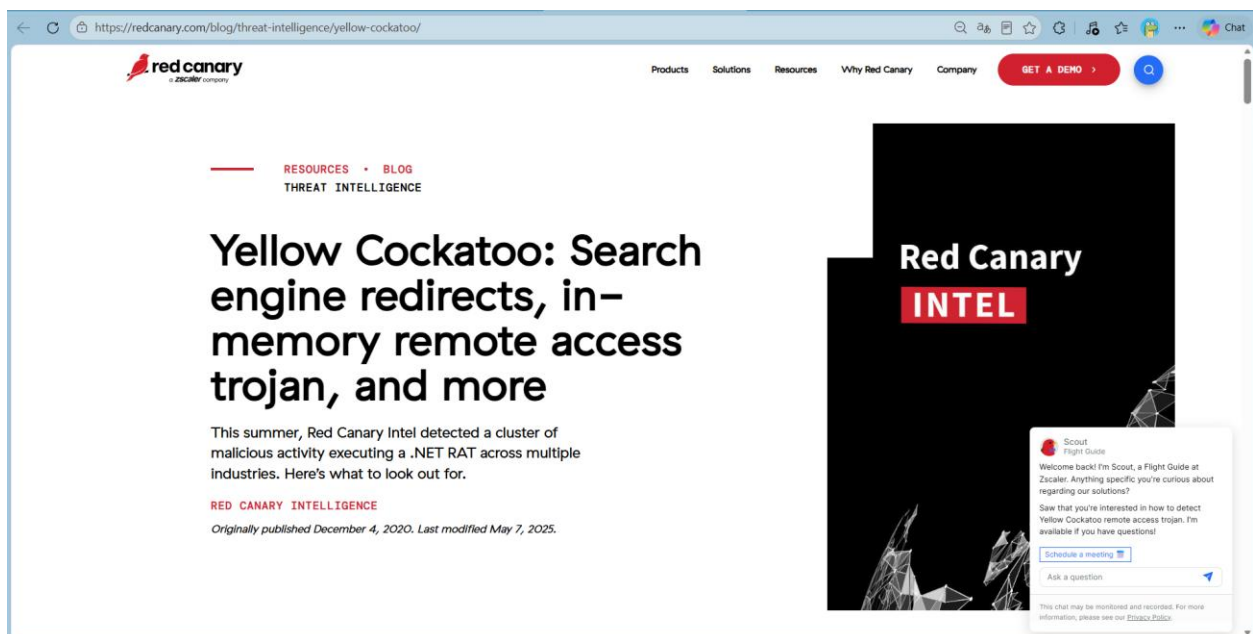
Tools: Text Editor

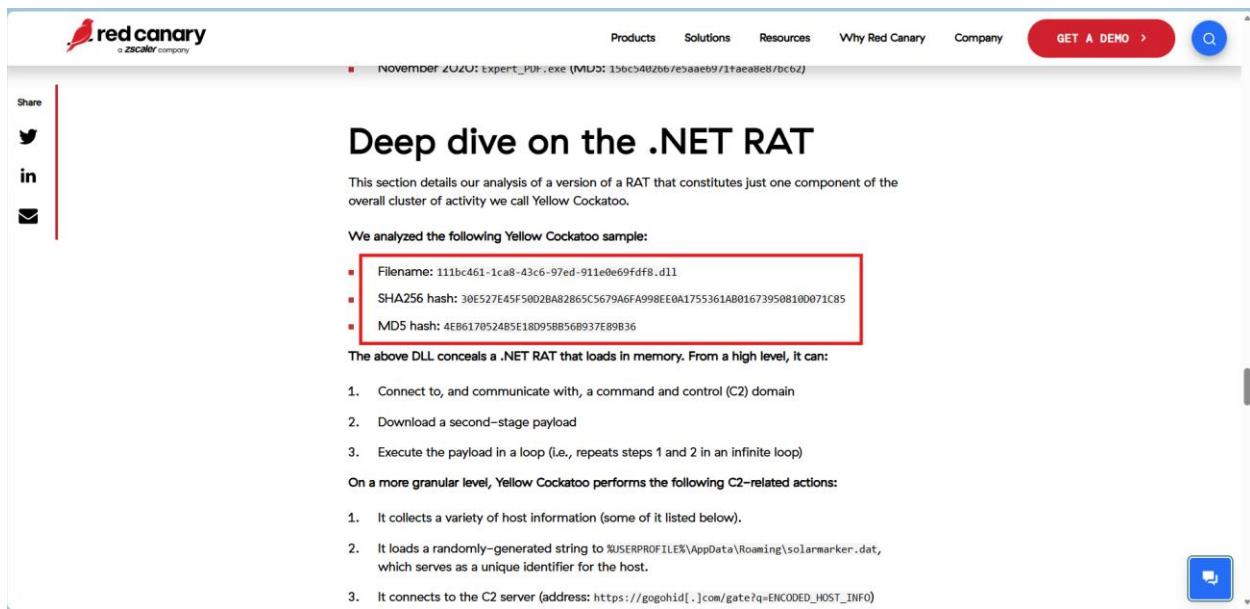
VIEWS LAB: [link](#)

Kịch bản: Analyze malware artifacts using threat intelligence platforms like VirusTotal to identify IOCs, C2 servers, and understand adversary tactics.

Q1

Understanding the adversary helps defend against attacks. What is the name of the malware family that causes abnormal network traffic? Use the naming convention published by the vendor that first documented and named this family in a public threat-intelligence report.



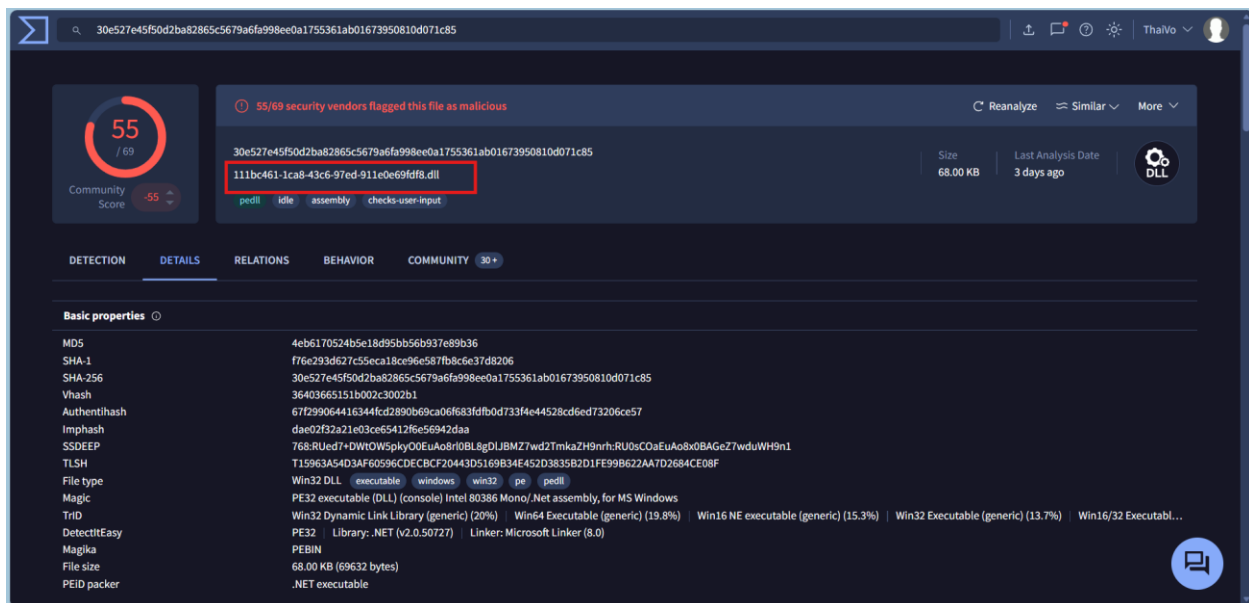


1. Mẫu đang được kiểm tra đã được xác định là một tệp DLL độc hại có hành vi phù hợp với Trojan truy cập từ xa (RAT). RAT đặc biệt nguy hiểm vì chúng cho phép kẻ tấn công điều khiển từ xa các hệ thống bị nhiễm, thực thi lệnh, lấy dữ liệu và triển khai thêm các thiết bị độc hại.
2. Phần mềm độc hại này là một .NET RAT dựa trên NET được thiết kế để thực thi lệnh trực tiếp trong bộ nhớ, bỏ qua các cơ chế phát hiện dựa trên đĩa. Chức năng chính của nó bao gồm thiết lập kết nối với các máy chủ lệnh và điều khiển (C2), tải xuống các payload phụ, và thực thi các lệnh theo vòng lặp để duy trì tính bền vững. Cần lưu ý rằng RAT này cũng thu thập thông tin máy chủ, có thể bao gồm chi tiết về hệ điều hành, cấu hình mạng và các thông tin xác thực có thể lưu trữ, cho thấy khả năng trinh sát và truy cập thông tin xác thực.

Q2

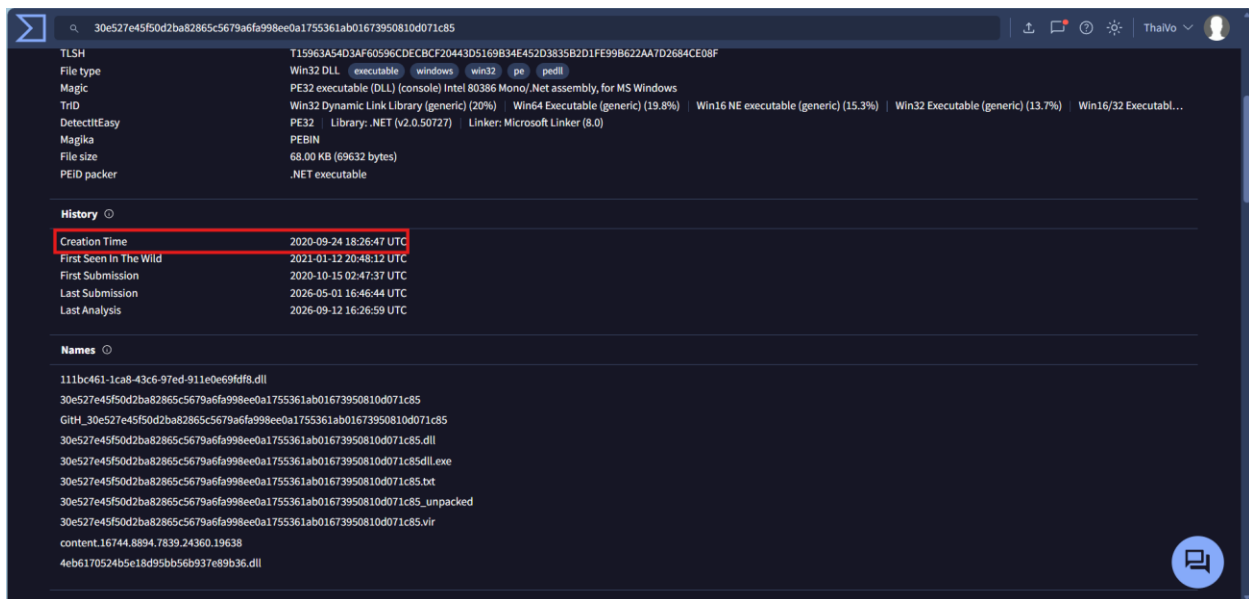
As part of our incident response, knowing common filenames the malware uses can help scan other workstations for potential infection. What is the common filename associated with the malware discovered on our workstations?

1. Việc phân tích tệp đáng ngờ được thực hiện bằng VirusTotal, một nền tảng phân tích phần mềm độc hại trực tuyến được sử dụng rộng rãi, tổng hợp kết quả từ nhiều công cụ diệt virus để đánh giá uy tín tệp và phát hiện các mối đe dọa tiềm ẩn.
2. Tệp này đã được 59 trong số 72 nhà cung cấp bảo mật đánh dấu là độc hại, điều này cho thấy nó liên quan đến hoạt động phần mềm độc hại đã biết. Tệp DLL này có đặc điểm của một trojan, như được thể hiện qua nhãn do các nhà cung cấp phần mềm diệt virus cung cấp



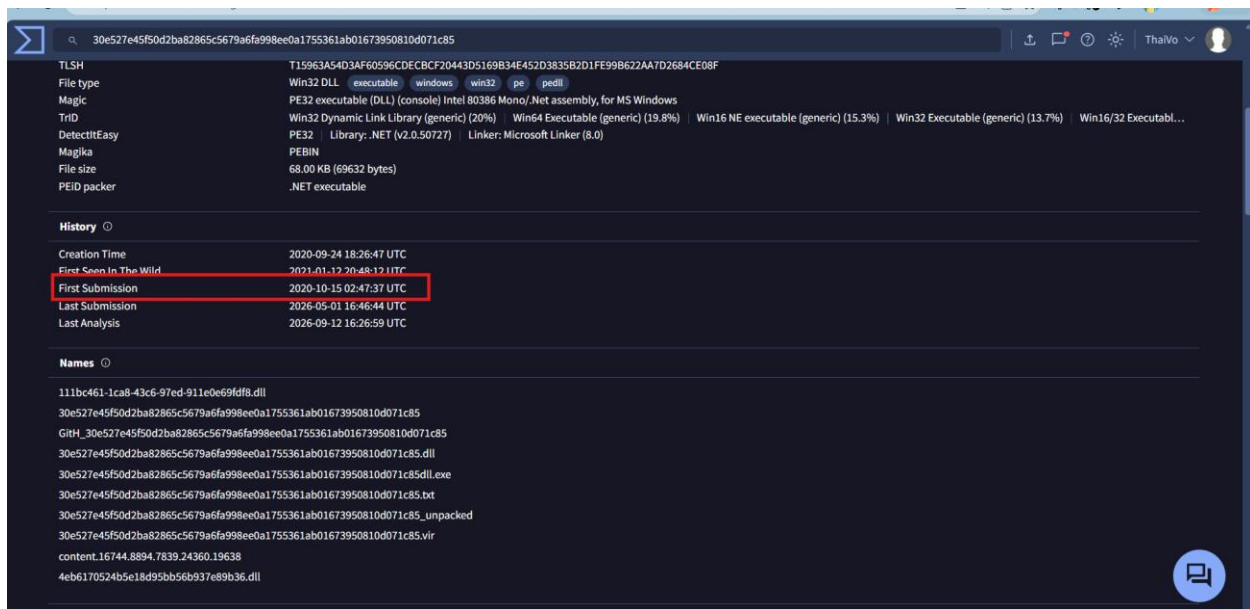
Q3

Determining the compilation timestamp of malware can reveal insights into its development and deployment timeline. What is the compilation timestamp of the malware that infected our network?



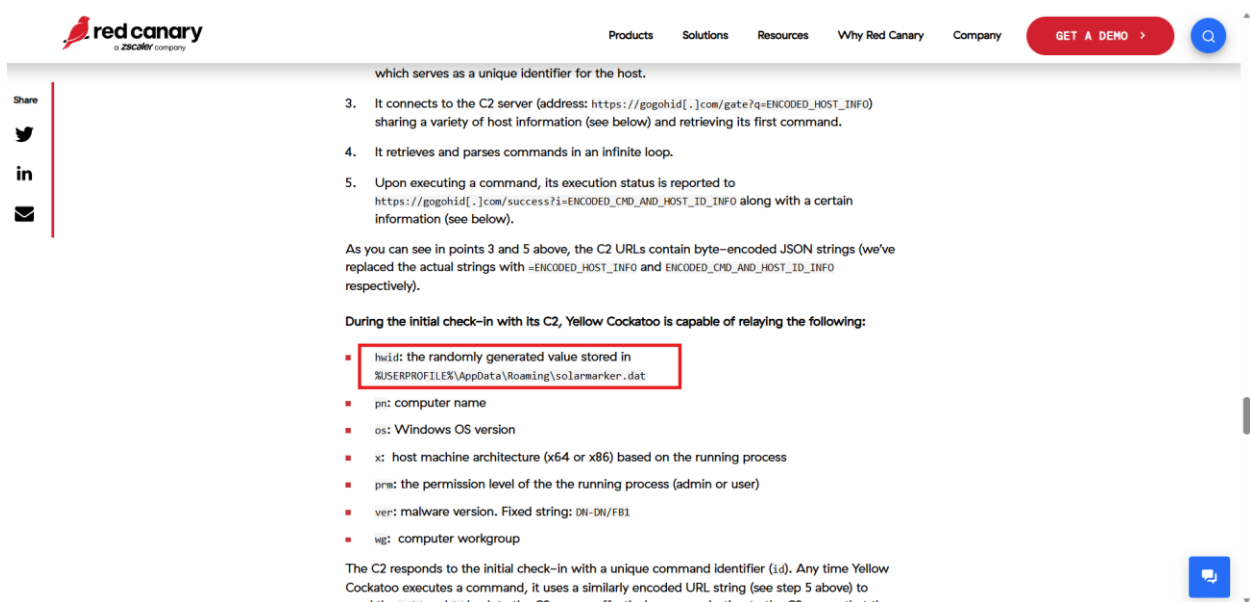
Q4

Understanding when the broader cybersecurity community first identified the malware could help determine how long the malware might have been in the environment before detection. When was the malware first submitted to VirusTotal?



Q5

To completely eradicate the threat from Industries' systems, we need to identify all components dropped by the malware. What is the name of the **.dat** file that the malware dropped in the **AppData** folder?



The screenshot displays the VirusTotal interface for a specific file hash. On the right, a YARA rule named 'Jupyter_Dropped_File' is shown, which is part of the 'solarmarker' ruleset. The rule's meta-information includes the author 'Lucas Acha' and a description: 'observed wide strings with malicious DLL loaded by Jupyter malware'. The rule's condition is 'all of them', indicating it triggers when all specified strings are found. On the left, the 'Crowdsourced YARA rules' section shows matches for this rule, and the 'Dynamic Analysis Sandbox Detections' section shows results from various sandboxes, all flagging the file as 'MALWARE'.

Q6

It is crucial to identify the C2 servers with which the malware communicates to block its communication and prevent further data exfiltration. What is the C2 server that the malware is communicating with?

The screenshot shows a blog post from Red Canary about the 'Yellow Cockatoo' malware. The post details the malware's C2-related actions. A red box highlights the fifth action: 'Upon executing a command, its execution status is reported to https://gogohid[.]com/success?i=ENCODED_CMD_AND_HOST_ID_INFO along with a certain information (see below)'. The post also mentions that the C2 server is gogohid.com.

1. Phân tích phần mềm độc hại liên quan đến chiến dịch Yellow Cockatoo cho thấy một trong những tên miền mà nó giao tiếp là gogohid.com. Tên miền này hoạt động như một máy chủ C2, hỗ trợ giao tiếp giữa các máy chủ bị nhiễm và hạ tầng của kẻ tấn công. Sự hiện diện của tên miền này trong hoạt động mạng của phần mềm độc hại làm nổi bật vai trò của nó trong việc duy trì quyền truy cập liên tục và truyền dữ liệu trở lại cho kẻ tấn công.

